

Vulnerability Management & Remediation Lifecycle: A Nessus Home Lab

Project Overview

This project demonstrates the full vulnerability management lifecycle - from intentional system misconfiguration and baseline scanning to patch management and remediation verification. Using Tenable Nessus, I conducted authenticated vulnerability scans against a local Windows Server 2022 environment to identify, prioritize, and resolve security weaknesses.

Environment & Tools

- **Hypervisor:** VMware Workstation
- **Scanner:** Kali Linux running Tenable Nessus Essentials
- **Target:** Windows Server 2022 (Domain Controller / Standalone)
- **Techniques Used:** Credentialed Scanning, Registry Editing, Local Security Policy Configuration, Patch Management.

Phase 1: Creating the Vulnerable Environment

To simulate a poorly maintained corporate server, I introduced several common misconfigurations and installed deprecated software onto the Windows Server 2022 virtual machine.

1. Installing Outdated Software

Third-party software is a major attack vector. I installed an obsolete version of Mozilla Firefox (Version 84.0) from the official Mozilla archive.

- **Action:** Installed Firefox 84.0 and explicitly disabled the Mozilla Maintenance Service and automatic updates to lock the software in a vulnerable state.

2. Weakening Password Policies

Using the Local Security Policy editor (secpol.msc), I removed standard password protections to simulate a weak Active Directory or local account environment.

- **Action:** Disabled password complexity requirements and changed the minimum password length.

3. Enabling the Guest Account

The built-in Guest account is disabled by default in modern Windows environments due to the risk of unauthenticated access.

- **Action:** Re-enabled the Guest account via Computer Management.

4. Network & Protocol Misconfigurations

To expose the server to network-based attacks and downgrade its internal security mechanisms, I modified several core Windows settings to simulate a severely neglected environment:

- Disabled the Windows Firewall
- Enabled Remote Desktop Protocol (RDP) to allow remote connections, but intentionally disabled Network Level Authentication (NLA)

Phase 2: Configuring the Baseline Scan

With the server thoroughly misconfigured, I moved to my Kali Linux VM to configure Tenable Nessus.

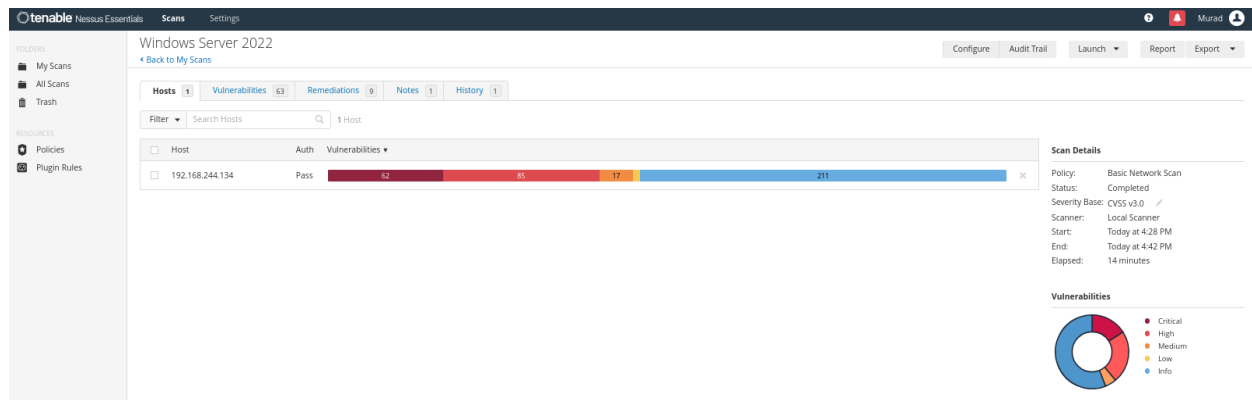
To ensure Nessus could see the registry changes, outdated software, and local policy misconfigurations, it was crucial to run an Authenticated (Credentialed) Scan.

- **Scan Type:** Basic Network Scan.
- **Discovery:** Port scan (common ports).
- **Authentication:** Provided the local Windows Administrator credentials.

Phase 3: Initial Scan Results

The baseline credentialed scan revealed a highly vulnerable environment, confirming that the intentional misconfigurations and outdated software were successfully detected.

- **High-Risk Posture:** The scan summary highlighted a severely compromised system, identifying 62 Critical, 85 High and 17 Medium vulnerabilities.



- **Key Findings:** The vulnerabilities list was dominated by the obsolete Mozilla Firefox installation and missing Windows OS / .NET Framework security updates.

Windows Server 2022
Back to My Scans

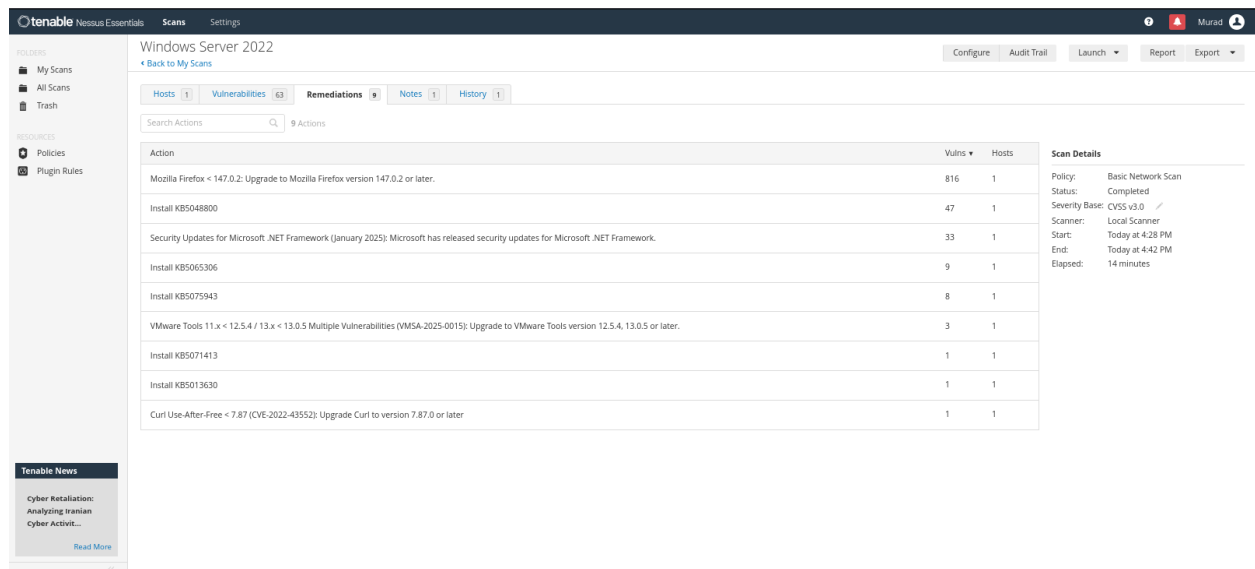
Configure Audit Trail

Hosts 1 Vulnerabilities 63 Remediations 9 Notes 1 History 1

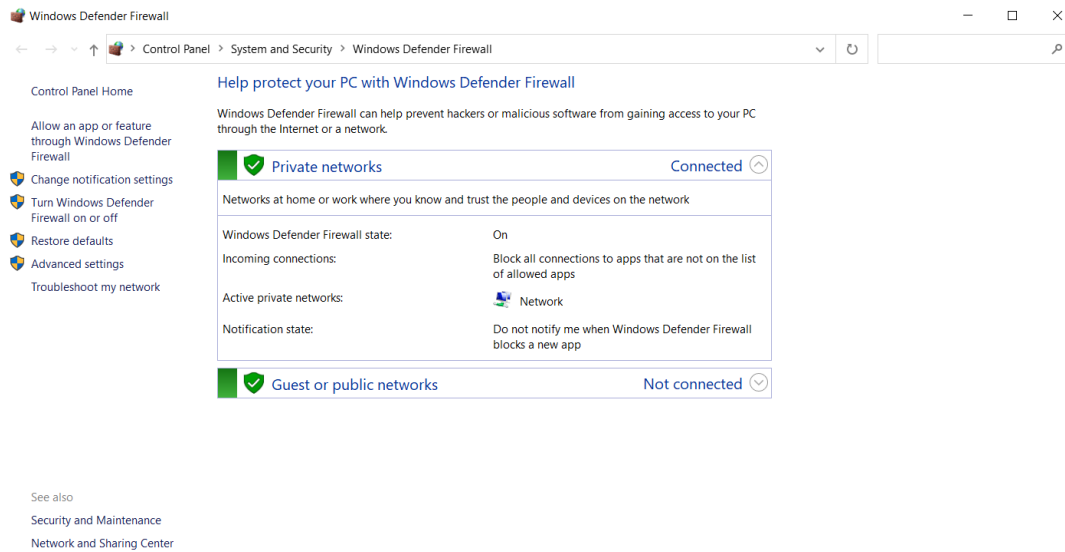
Filter Search Vulnerabilities 63 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count	
MIXED	...	...	...	Mozilla Firefox (Multiple Issues)	Windows	86	
MIXED	...	...	...	Microsoft Azure Stack Hci (Multiple Issues)	Windows : Microsoft Bulletins	21	
MIXED	...	...	...	Microsoft Azure Stack Hci 22h2 (Multiple Issues)	Windows : Microsoft Bulletins	16	
MIXED	...	...	...	Microsoft .NET Framework (Multiple Issues)	Windows : Microsoft Bulletins	15	
MIXED	...	...	...	Microsoft Windows Server 2022 (Multiple Issues)	Windows : Microsoft Bulletins	10	
MIXED	...	...	...	SSL (Multiple Issues)	General	7	
MIXED	...	...	...	VMware Tools (Multiple Issues)	Windows	3	
MIXED	...	...	...	Microsoft Windows (Multiple Issues)	Windows : Microsoft Bulletins	2	
MIXED	...	...	...	VMware Tools (Multiple Issues)	Misc.	2	
HIGH	...	...	...	Mozilla Firefox SEoL (84.x)	Misc.	1	
MEDIUM	5.3	...	...	SMB Signing not required	Misc.	1	
MIXED	...	...	...	Microsoft Windows (Multiple Issues)	Windows	87	
MIXED	...	...	...	TLS (Multiple Issues)	Service detection	4	
MIXED	...	...	...	Haax Curl (Multiple Issues)	Windows	3	

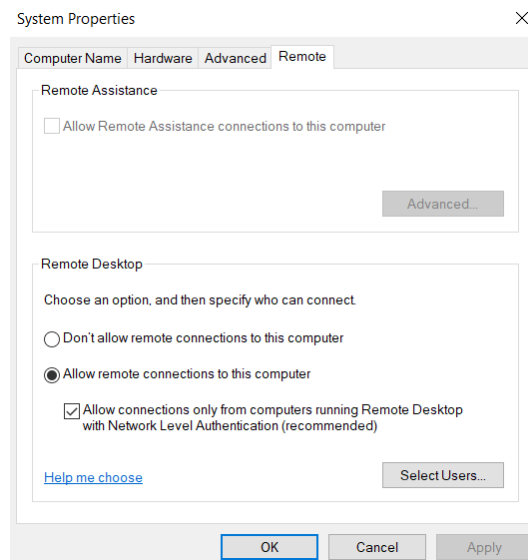
- **Remediation Prioritization:** The Remediations tab provided a clear action plan, demonstrating that simply upgrading Firefox and installing a handful of Microsoft KBs (like KB5048800) would resolve the vast majority of the identified threats.



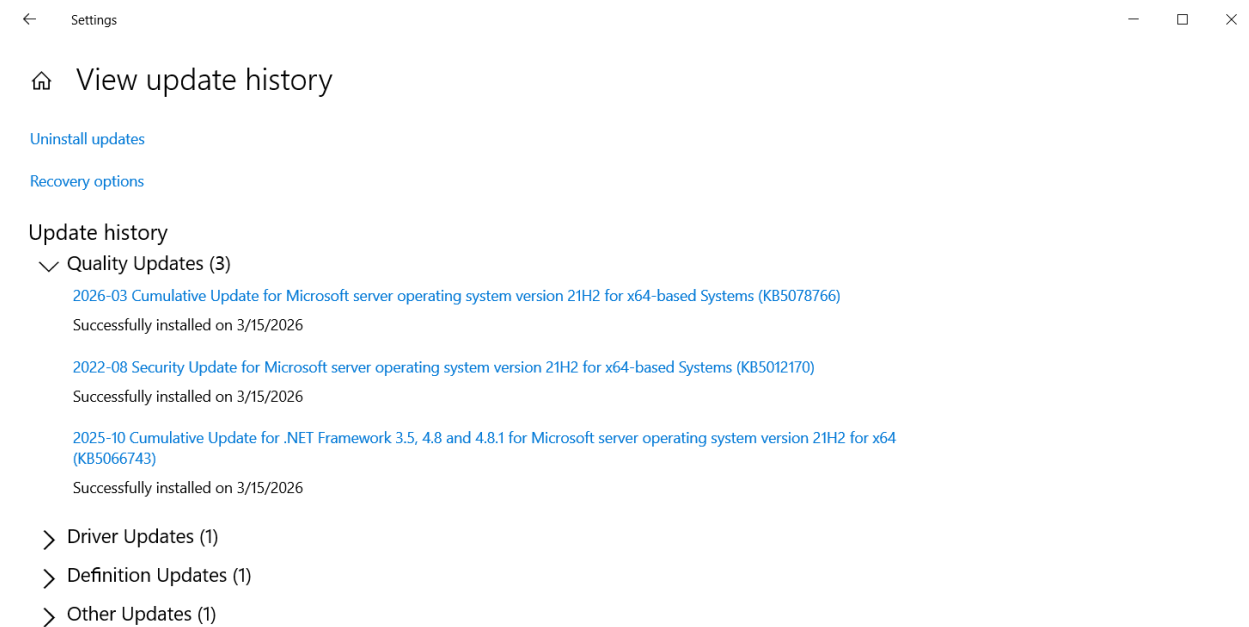
- **Network Defense Restoration:** Enabled the Windows Defender Firewall to restore primary host-based network protection and block unauthorized inbound traffic.



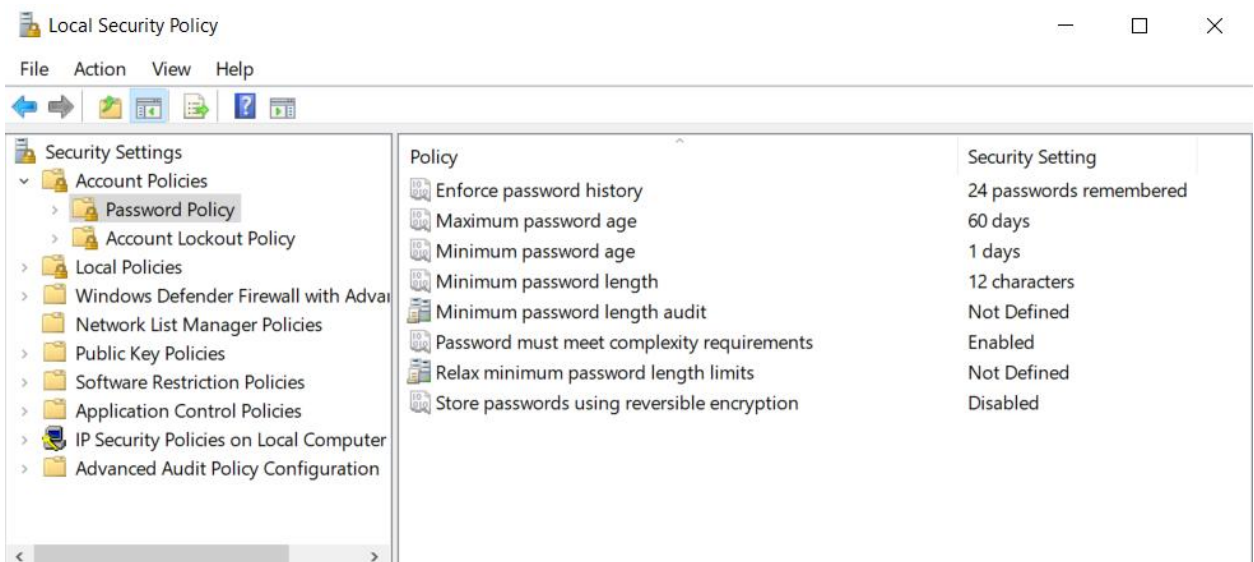
- **Protocol Security Hardening:** Restored Network Level Authentication (NLA) for Remote Desktop Protocol (RDP) to enforce authenticated connections and mitigate Man-in-the-Middle (MitM) attacks.



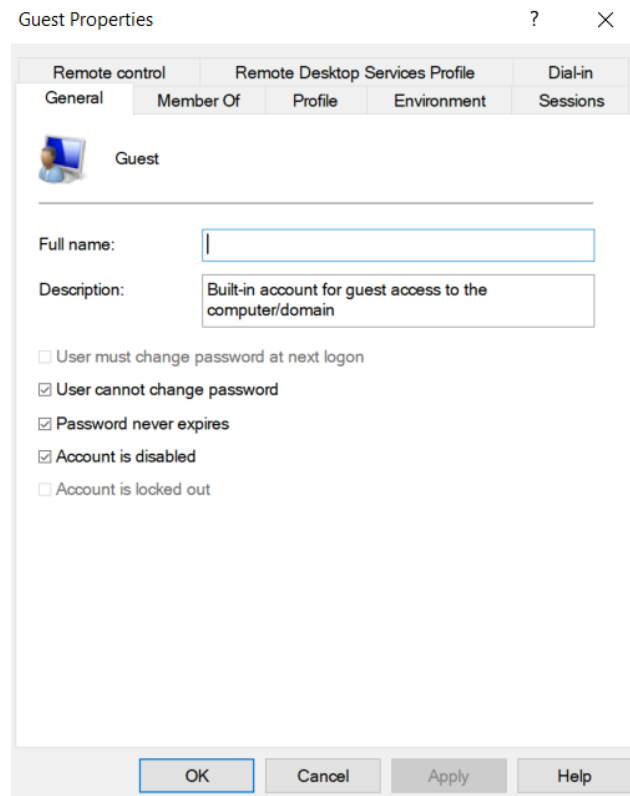
- **Operating System Updates:** Applied missing Microsoft security patches to address OS-level vulnerabilities flagged in the initial scan.



- **Identity & Access Management:** Restored strict local security policies, requiring password complexity, a 12-character minimum length, a 60-day maximum age, and a 24-password history to defend against brute-force and dictionary attacks.



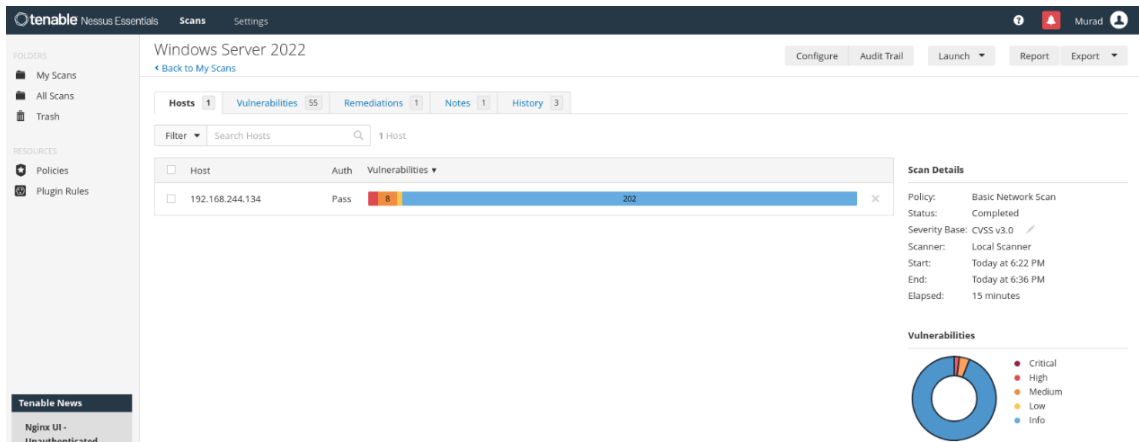
- **Account Hardening:** Disabled the built-in Windows Guest account to prevent anonymous, unauthenticated access to the server.



Phase 5: Verification & Reporting

To verify the effectiveness of the applied remediations, I conducted a final authenticated vulnerability scan.

- **Post-Remediation Scan:** The final credentialed scan confirmed the successful remediation of the targeted misconfigurations and outdated software.
- **Risk Reduction:** The environment's overall risk posture was drastically improved. All **62 Critical** vulnerabilities were completely eliminated (100% reduction), and the **85 High** vulnerabilities were reduced to just **4** (a 95% reduction). This demonstrates a successful, measurable vulnerability management lifecycle from discovery to verification.



- **Remediation Tracking:** I documented the scan results in a tracking spreadsheet. The generated area chart visually demonstrates a massive 92% drop in total vulnerabilities (from 165 down to 13) across a single remediation cycle.

